

Pretexting

64.9k views

Attack Types



Pretexting Definition

Pretexting is a certain type of [social engineering](#) technique that manipulates victims into divulging information. A pretext is a made-up scenario developed by threat actors for the purpose of stealing a victim's personal data.

During pretexting attacks, [threat](#) actors typically ask victims for certain information, stating that it is needed to confirm the victim's identity. In reality, the threat actor steals this information and then uses it to carry out secondary attacks or identity theft.

Sophisticated pretexting attacks may attempt to trick victims into performing an action that exploits the physical and/or digital weaknesses of an organization. For example, a threat actor might pretend to be an external IT services auditor and use this alias to convince the physical security team of an organization to allow the threat actor to enter the building.

Many threat actors who adopt this attack type masquerade as employees or HR personnel in the finance department. These disguises let them target C-level executives or other employees with extensive privileges, who are more valuable for attackers.

While phishing attacks tend to use urgency and fear to exploit victims, pretexting attacks establish a false sense of trust with a targeted victim. This requires threat actors to establish a credible story that does not make victims suspicious of any foul play.

Pretexting Attack Techniques

Pretexters use a variety of tactics and techniques to gain the trust of their targets and convince them to hand over valuable information.



Types of pretexting attacks

Impersonation

Welcome to Imperva! 🍌 How can I direct you?

An impersonator imitates the behavior of another actor, usually a trusted person such as a colleague or friend. This involves maintaining a sense of credibility, often by spoofing the phone numbers or email addresses of impersonated institutions or individuals.

An example of impersonation is the SIM swap scam, which exploits [vulnerabilities in two-step verification](#) processes including SMS or phone verification to take over target accounts. The pretexter impersonates a victim and claims to have lost their phone and persuades the mobile operator to switch the phone number to the attacker's SIM. One-time passwords are then forwarded to the attacker instead of the victim.

One successful social engineering attack involving impersonation was the 2015 attack on Ubiquiti Networks. Employees received messages from pretexters impersonating senior executives of the company and requesting payments to the attackers' bank accounts. This cost the company \$46.7 million.

Tailgating

Tailgating is a social engineering technique that enables threat actors to gain physical [access to facilities](#). To tailgate means to closely follow authorized personnel into a facility without being noticed. After reaching the entrance, the threat actor may quickly stick their foot or any other object into the door before it is completely shut and locked.

Piggybacking

Piggybacking is very similar to tailgating, except that the authorized individual is not only aware of the actor but also allows the actor to "piggyback" off the credentials. For example, authorized personnel arrives at the entrance of a facility. The individual approaches and asks for help, claiming to have forgotten their access badge. It could also be a woman holding heavy boxes. Either way, authorized personnel may decide to help these individuals to gain access to the building.

Baiting

A baiting attack is an attempt to make an attractive promise that will lure the victim into a trap. Typically, the [attacker](#) aims to spread [malware](#) or steal [sensitive information](#).

Baiting attacks may use hardware like malware-infected flash drives as bait, often adding something that gives it an authentic look, such as a company label.

The bait is placed in commonly visited locations, such as lobbies, bus stations, or bathrooms. The attacker will place the bait in a way that victims will notice it and have an incentive to insert it into a personal or work device. The bait hardware will then deploy malicious software on the device.

Baiting schemes can also be carried out online. For example, enticing ads can lead victims to malicious websites or encourage victims to download a malware-infected application.

Phishing

[Phishing](#) involves impersonating a trusted entity in communications like emails or text messages, in order to obtain sensitive information like payment card details and passwords. Phishing is a separate category from pretexting, but these can be combined—phishing attempts often leverage a pretexting scenario.

Pretexting increases the chances of a phishing attempt being successful, for example, if target employees believe they are talking to a contractor or employer. [Compromised](#) employee accounts can also be used for further pretexting attacks that target individuals through spear phishing.

For example, the Canadian MacEwan University in Canada fell victim to a phishing scam in 2017, which cost the university around \$9 million. The targeted staff changed payment details, believing the scammer was a contractor.

Vishing and Smishing

Voice phishing (or vishing) is a social engineering technique. This type of attack uses phone calls to trick victims into disclosing sensitive information or giving attackers remote access to the victim's computer device.

For example, a common vishing scheme involves the threat actor calling victims while pretending to be an official from the IRS. The attacker often threatens or attempts to scare the victim into giving compensation or [personal information](#). IRS vishing schemes usually target older individuals. However, anyone can be tricked by a vishing scam when not adequately trained.

SMS phishing (or smishing) is a form of social engineering similar to vishing and phishing. It uses the same techniques but is perpetuated via SMS or text messaging.

Scareware

A scareware attack bombards victims with fictitious threats and false alarms. The victim is deceived into thinking that their system is infected with malware. They are then prompted to install malware or software that somehow benefits the threat actor. Scareware is also known as deception software, fraudware, and rogue scanner software.

For example, a common scareware attack involves displaying legitimate-looking popup banners in the browser of a victim surfing [the web](#). The banner may display a text message such as, "Your computer may be infected with harmful spyware programs." The scareware then offers to install a certain tool (usually malware-infected) for the victim, or directs the victim to a malicious website where the computer becomes infected.

Scareware can also be distributed through spam emails that include bogus warnings or encourage victims to purchase worthless or harmful services.

Pretexting and the Law

Pretexting is, in general, illegal in the United States. For [financial institutions](#) governed by the Gramm-Leach-Bliley Act of 1999 (GLBA) (almost all financial institutions), it is illegal for any individual to attempt to obtain, actually obtain, or cause an employee to disclose customer information by deception or false pretenses. GLBA-regulated institutions must also enforce standards to educate their staff to identify pretexting attempts.

In 2006, Congress passed the Telephone Records and Privacy Protection Act of 2006, which extends protection to records kept by telecom companies. However, in other industries, it is not completely clear if pretexting is illegal. In future court cases, prosecutors will need to decide which laws to use to file charges under, many of which were not created with this scenario in mind.

How to Prevent Pretexting

Here are several methods businesses are using to protect themselves against pretexting.

DMARC

Pretexting includes impersonation, and to be successful the email must appear genuine. Thus, email spoofing is necessary. Domain-based Message Authentication, Reporting, and Conformance (DMARC) is the most prevalent form of protection for email spoofing, yet it is limited, as it requires continual and complex maintenance.

What's more, DMARC stops exact domain spoofing but does not display name spoofing or cousin [domains spoofing](#), which are far more prevalent in [spear-phishing attacks](#). Attackers have adopted these more sophisticated techniques mainly due to the effectiveness of DMARC.

AI-Based Email Analysis

To stop pretexting, businesses must strive for a more modern method of detection than DMARC. Next-generation anti-spear phishing technology uses artificial intelligence (AI) to study user behaviors and detect indications of pretexting. Furthermore, it can find anomalies in email addresses and in email traffic, such as display name spoofing and cousin domains. Natural Language Processing (NLP), a part of AI, examines language and can decipher phrases and words common in spear-phishing and pretexting.

User Education

Lastly, educate your users so they can identify pretexting by sharing real-life pretexting instances with them. Often, what makes spear-phishing and pretexting successful is that users are not familiar with the pretexting tactics mentioned above, and notice nothing abnormal about the requests they receive.

Educate users about the various sorts of email spoofing and train them to study email addresses for signs of display name spoofing and cousin domains. You must also have established rules about financial transactions, including validating requests in person or over the phone.

Pretexting Protection with Imperva

Imperva provides its industry-leading [Web Application Firewall](#), which prevents pretexting attacks with world-class analysis of web traffic to your applications.

Beyond social engineering protection, Imperva provides comprehensive protection for applications, [APIs](#), and microservices:

Runtime Application Self-Protection (RASP) – Real-time attack detection and prevention from your application runtime environment goes wherever your applications go. Stop external attacks and [injections](#) and reduce your vulnerability backlog.

API Security – Automated API protection ensures your API endpoints are protected as they are published, shielding your applications from exploitation.

Advanced Bot Protection – Prevent business logic attacks from all access points – websites, mobile apps, and APIs. Gain seamless visibility and control over bot traffic to stop online fraud through account takeover or competitive price scraping.

DDoS Protection – Block attack traffic at the edge to ensure business continuity with guaranteed uptime and no performance impact. Secure your on-premises or cloud-based assets – whether you're hosted in AWS, Microsoft Azure, or Google Public Cloud.

Attack Analytics – Ensures complete visibility with machine learning and domain expertise across the [application security](#) stack to reveal patterns in the noise and detect application attacks, enabling you to isolate and prevent attack campaigns.

Client-Side Protection – Gain visibility and control over third-party JavaScript code to reduce the risk of supply chain fraud, prevent data [breaches](#), and client-side attacks.

Latest Blogs

Imperva Threat Research

Beware! A threat actor could steal the titles of your private (and draft) WordPress[...]

**Yannick Sillam**
May 16, 2025 5 min read

Imperva Threat Research

Early 2025 DDoS Attacks Signal a Dangerous Trend in Cybersecurity

**Gabi Sharadin, Muly Levy**
May 7, 2025 6 min read

Imperva Threat Research

From PyPI to the Dark Marketplace: How a Malicious Package Fuels the Sale of[...]

**Sarit, Liran**
Apr 16, 2025 4 min read

Imperva Threat Research

Imperva Protects 2025-31

**Gal**
Apr



Latest Articles

App Security ...

Phishing attacks

App Security ...

Social Engineering

App Security ...

SQL (Structured query

App Security ...

Man in the middle (MITM) attack

App Security ...

Cross site request forgery (CSRF) attack

Netw Secu

Bootstrapping DDoS

842.3k Views

780.2k Views

language)
Injection
537.7k Views

367.7k Views

366.2k Views

351.4k



+1 866 926 4678

Partners

- Imperva Partner Ecosystem
- Channel Partners
- Technology Alliances
- Find a Partner
- Partner Portal Login

About Us

- Why Imperva
- Who We Are
- Events
- Careers
- Press & Awards
- Contact Information

Support

- Emergency DDoS Protection
- Support Portal
- Imperva Community
- Documentation Portal
- API Integration
- Trust Center

Resources

- Imperva Blog
- Resource Library
- Case Studies
- Learning Center

Network

- Network Map
- System Status

English



Cookies Settings

Trust Center

Modern Slavery Statement

Privacy

Legal